

Reporte Ejecutivo: Auditoría de Seguridad y Gestión de Riesgos

Clínica Privada — Gestión de Riesgos de Seguridad de la Información

Fecha: 2 de septiembre de 2026

Para: Directorio, Clínica Privada

De: Equipo de Auditoría de Sistemas de Información

Resumen Ejecutivo

La reciente evaluación de la infraestructura tecnológica de la clínica ha revelado vulnerabilidades críticas que amenazan directamente la continuidad operativa y la confidencialidad de los 800 pacientes atendidos diariamente. Mediante el análisis en la plataforma SimpleRisk, se identificaron brechas severas en la red perimetral, los servidores centrales y el código del portal web.

Al igual que el lobo feroz se presentó ante la Caperucita Roja disfrazado de figura confiable para ganar acceso a un lugar protegido, los atacantes externos identificados en esta auditoría explotan vulnerabilidades técnicas — como la inyección SQL del portal web — simulando solicitudes legítimas para infiltrarse en sistemas que resguardan información sensible de pacientes.

La no remediación inmediata de estos hallazgos expone a la institución a paradas totales de servicio, pérdida irrecuperable de historias clínicas y acciones legales millonarias por incumplimiento de la Ley de Protección de Datos Personales. El objetivo de este informe es presentar los riesgos priorizados y solicitar la aprobación inmediata de los presupuestos necesarios para la mitigación técnica.

Top 5 Riesgos por Nivel

A continuación se detallan los 5 riesgos operativos de mayor criticidad, priorizados según su potencial impacto financiero, legal y operativo sobre la institución:

- 1. Infección por Ransomware en Servidores Centrales (Nivel Crítico):** Existe un riesgo inminente de secuestro y cifrado de los servidores principales de la clínica. Un ataque exitoso paralizaría por completo la atención médica, la gestión de turnos y la facturación, exigiendo el pago de rescates exorbitantes.
- 2. Exposición de Datos por Inyección SQL en Portal Web (Nivel Crítico):** Se detectó una vulnerabilidad crítica en el portal web que permite a atacantes externos ejecutar comandos maliciosos en la base de datos. Esto facilita la exfiltración masiva, alteración o eliminación de historias clínicas completas.
- 3. Compromiso de la Red Interna (Nivel Alto):** La ausencia de políticas estrictas de Firewall y Sistemas de Prevención de Intrusiones (IPS) en la red perimetral facilita el acceso no autorizado desde internet hacia la red interna corporativa y los equipos de diagnóstico.
- 4. Pérdida de Datos por Falla de Backups Físicos (Nivel Alto):** La infraestructura actual almacena las copias de seguridad en el mismo cuarto físico que los servidores. Un desastre ambiental (incendio, inundación) o eléctrico provocaría la destrucción simultánea del sistema principal y sus respaldos, resultando en una pérdida de datos irrecuperable.
- 5. Robo de Credenciales sin MFA (Nivel Alto):** Los accesos remotos al sistema médico dependen exclusivamente de un usuario y contraseña. El compromiso de una sola credencial válida permite el acceso total al sistema debido a la falta de Autenticación Multifactor (MFA).

Estado de los Planes de Acción

Se han diseñado planes de mitigación técnica específicos para neutralizar las vulnerabilidades más urgentes. A continuación se detalla el estado actual, el esfuerzo requerido y el presupuesto asociado para cada iniciativa:

Riesgo Objetivo	Solución Técnica Propuesta	Esfuerzo Técnico	Presupuesto (USD)	Estado Actual
Ransomware	Despliegue de agente EDR (Endpoint Detection & Response) en servidores y configuración de Backups Inmutables (off-site / nube).	Significativo	\$4.500	Pendiente de Aprobación
Inyección SQL	Refactorización profunda del código backend (uso de Prepared Statements) y despliegue de un Web Application Firewall (WAF).	Significativo	\$1.200	Pendiente de Aprobación
Credenciales	Integración de Autenticación Multifactor (TOTP) de carácter obligatorio para todo el personal médico y administrativo.	Considerable	\$800	Pendiente de Aprobación

Siguiendo la lógica del cuento de los tres chanchitos, cuya casa de ladrillos fue la única que resistió al lobo gracias a una construcción robusta y no a una única barrera, el plan de mitigación propuesto combina múltiples capas de defensa — detección y respuesta en endpoints (EDR), un firewall de aplicaciones web (WAF) y autenticación multifactor (MFA) — en lugar de depender de un solo control. Esta estrategia de defensa en profundidad reduce la probabilidad de que el compromiso de una sola capa derive en un incidente total.

Estado de los Planes de Acción

Basado en el análisis de riesgos, se recomienda encarecidamente al directorio tomar las siguientes acciones inmediatas:

- **Aprobación Presupuestaria:** liberar de forma urgente la partida de \$6.500 USD para ejecutar los tres planes de mitigación críticos. Esta inversión preventiva es marginal en comparación con las potenciales sanciones legales y el lucro cesante de una parálisis operativa.
- **Despliegue Inmediato de EDR:** iniciar la instalación de la solución EDR en los servidores críticos y establecer las copias de seguridad inmutables en la nube en un plazo no mayor a 48 horas.
- **Ventana de Mantenimiento de Emergencia:** coordinar con el equipo de desarrollo backend para aislar la base de datos de pacientes y aplicar los parches de seguridad (Prepared Statements) en el portal web de manera prioritaria.
- **Revisión de Accesos:** establecer una auditoría trimestral de cuentas médicas para revocar accesos inactivos y asegurar que los permisos se otorguen estrictamente bajo el principio de menor privilegio.
- **Ubicación Física de Infraestructura Crítica:** verificar que los racks de servidores y los equipos de backup no se encuentren adyacentes a cocinas o áreas de calefacción (riesgo de incendio) ni en zonas ubicadas debajo de baños, cocinas o piletas (riesgo de inundación).